Auditoría del módulo de importaciones

Cierre de revisión: 2026-10-22, America/Costa_Rica. Revisión iniciada el 21 de octubre. Base: `dcb214c` y cambios locales presentes; se preservaron las remediaciones anteriores de lotes/reportes. Instrucción: Agents.md.

1. Resumen ejecutivo

El importador tiene una vista previa persistida y aislada por usuario, organización y finca, mapea columnas permitidas y aplica reserva de cupo al crear/reactivar animales activos. Sin embargo, **no está listo para considerarse seguro e íntegro en todos sus flujos**: se identifican **20 hallazgos: 2 P0 de seguridad, 16 P1 de integridad/reglas operativas y 2 P2 de experiencia de usuario**.

Los P0 corresponden al parser vulnerable y al procesamiento sin límites de descompresión/dimensiones, en el mismo proceso del servidor. **No se confirmó acceso cruzado a datos de otra organización** ni ejecución de código remoto. La prioridad P0 sigue la clasificación de seguridad solicitada; no significa que npm asigne severidad crítica a ambos problemas.

Riesgos silenciosos detectados

- Una importación mínima puede reactivar un vendido, cambiar Enfermo a Sano y reemplazar el objetivo productivo por SIN_DEFINIR, aunque esas columnas no se hayan enviado.
- Dos confirmaciones simultáneas pueden aplicar el mismo snapshot dos veces. Las finanzas no tienen deduplicación por fila y se duplican al confirmar nuevos snapshots del mismo contenido.
- `solo_crear` omite la edición principal de un animal existente, pero después puede moverlo de lote y modificar sus padres.
- `PESO_ACTUAL_KG` puede modificar Animal sin crear Pesaje ni evento. Un fallo posterior al guardar un pesaje puede dejar peso y bitácora desincronizados.
- Se aceptan relaciones genealógicas de sexo/especie incorrectos, autorreferencias y categorías incompatibles con sexo cuando falta nacimiento.
- Fechas Excel y fechas escritas como texto del mismo día producen días distintos si Node opera en Costa Rica.
- El usuario ve un resumen de errores al confirmar, pero no sus filas/motivos. Puede reintentar una carga parcial sin saber qué ya se guardó.

Evidencia y límites

- Reproducciones ejecutables: **26 verificaciones** con libros XLSX/XML reales, código de servicio/controlador real y almacenamiento simulado. Incluyen errores inducidos, concurrencia de controlador, reglas reales de plan, validación Mongoose sin persistencia y hooks de aislamiento.
- `npm.cmd test` desde backend: **289 aprobadas**, cero fallos, cero omitidas. Las pruebas existentes no cubrían todos los defectos aquí reproducidos.
- `npm.cmd audit --omit=dev --json`: consulta completada, salida 1 por vulnerabilidades; dos paquetes afectados: xlsx (high) y proxy-addr (critical). El intento inicial limitado por sandbox no pudo acceder al registro; la consulta autorizada sí devolvió resultados. No se ejecutó `audit fix` ni se instalaron paquetes.
- No se usaron bases de datos, archivos ni cuentas de producción. Las pruebas no certifican concurrencia real de índices/transacciones de MongoDB ni la integración HTTP autenticada. Los repositorios simulados no ejecutan todos los hooks de Mongoose; los resultados se interpretan con ese límite.
- La sonda de dimensión extrema se ejecutó **solo en proceso hijo**, con 192 MB de heap y corte de 3 segundos. No se envió a un servidor compartido. No se ensayó una zip bomb sin límites ni el exploit específico de cada CVE.
- Esta entrega modifica únicamente documentación y el reproductor de auditoría. **Los hallazgos no se remediaron en código operativo.** No se recompiló frontend: no se cambió su implementación en esta fase.

2. Catálogo de entidades, columnas y flujo real

Fuentes: importar.js, importar-controller.js, importarExcel-service.js, ImportarExcel.js.

Ruta	Función real	Acceso
GET `/api/importar/plantilla`	Genera XLSX versión `1` con catálogos activos	Sesión + finca autorizada + `importar.gestionar`
POST `/api/importar/excel`	Recibe campo multipart `archivo`, parsea/valida y guarda snapshot de preview	Mismos guards; Multer después del permiso

Ruta	Función real	Acceso
POST `/api/importar/excel/confirmar`	Lee snapshot por ID/usuario y ejecuta sus filas	Mismos guards; sin middleware general de plan vigente

Solo **Administrador** tiene `importar.gestionar`; coincide con la visibilidad del frontend. No hay feature exclusiva de importación: las rutas están disponibles desde Esencial. Las reglas de plan se verifican selectivamente dentro del servicio, no en todo el flujo.

Entidad / hoja	Columnas	Validaciones reales	¿Transaccional?	¿Idempotente?	¿Respeta cupo?	Madurez
Potrero / POTREROS	Lista P completa abajo	Código/nombre, números no negativos, enums, formato de fecha, código repetido en archivo	No; potrero y cobertura se guardan por separado	Parcial por código; susceptible a concurrencia y defaults	No aplica cupo de animales; sin guard general de suscripción	Parcial
Animal / INVENTARIO	Lista A completa abajo	DIIO, especie/sexo/categoría, fechas sintácticas, lote existente/compatible, fracciones raciales	No; reserva de cupo no es transacción de toda la fila; pasos posteriores de lote pueden tener transacción propia	Parcial por DIIO **o** identificador; sin identidad inequívoca para ambos	Sí para altas/reactivaciones activas, de una en una; no reserva del archivo	Parcial
MovimientoFinanciero / FINANZAS	Lista F completa abajo	Fecha, enums, catálogo, monto ≥0 y moneda CRC/USD	No	No por fila; hash de archivo solo bloquea ciertos reenvíos	No aplica cupo animal; sin bloqueo general por plan suspendido	Riesgo alto de duplicación
Pesaje / PESAJES	Lista W completa abajo	Animal conocido en preview, peso >0, fecha, repetición DIIO/día; fecha futura/anterior al nacimiento se valida al confirmar	No; pesaje, evento y peso derivado no son una unidad	Parcial por animal/día; índice no único, vulnerable a concurrencia	No consume cupo; sin guard general de suscripción	Parcial

No hay hojas operativas para sanidad, reproducción, compras/ventas como documentos de negocio, semen, bodega, leche ni rotaciones. Los lotes **no se crean**: INVENTARIO puede vincular animales a lotes existentes. FINANZAS admite tipos «Compra de animales»/«Venta de animales», pero crea únicamente un MovimientoFinanciero, no un CompraAnimal/VentaAnimal ni sus efectos sobre ganado.

P. POTREROS

Obligatorias: `CODIGO`, `NOMBRE`.

Opcionales: `AREA_HECTAREAS`, `CAPACIDAD_MAXIMA`, `UBICACION`, `ESTADO`, `TIPO_AREA`, `PASTO`, `PASTO_PRINCIPAL`, `TIPO_PASTO`, `FECHA_ESTABLECIMIENTO_PASTO`, `DIAS_DESCANSO_OBJETIVO`, `INTERVALO_CORTE_OBJETIVO_DIAS`, `OBSERVACION_COBERTURA`, `OBSERVACIONES`.

La plantilla genera la variante canónica `PASTO_PRINCIPAL`; `PASTO` y `TIPO_PASTO` son aliases aceptados que no aparecen en sus encabezados. PASTOREO/BANCO_FORRAJERO describen áreas de finca, no inventario de bodega. Un pasto desconocido se conserva como descripción con advertencia.

A. INVENTARIO

Obligatorias: `DIIO`, `ESPECIE`, `SEXO`, `CATEGORIA`.

Opcionales: `NOMBRE`, `RAZA`, `RAZA_PRINCIPAL`, `RAZA_SECUNDARIA`, `DESCRIPCION_RACIAL`, `GRADO_RACIAL`, `VARIEDAD_RACIAL`, `COMPOSICION_RACIAL`, `FRACCION_RAZA_PRINCIPAL`, `FRACCION_RAZA_SECUNDARIA`, `FECHA_NACIMIENTO`, `MADRE_DIIO`, `PADRE_DIIO`,

`PESO_ACTUAL_KG`, `OBJETIVO_PRODUCTIVO`, `ETAPA_PRODUCTIVA`, `ESTADO`, `ESTADO_SANITARIO`, `POTRERO_CODIGO`, `CODIGO_LOTE`, `NOMBRE_LOTE`, `PROPOSITO_LOTE`, `OBSERVACIONES`.

`DIIO` se copia tanto a `diio` como a `identificadorFinca`; no existe una columna independiente para identificador interno. `NOMBRE_LOTE` se acepta pero no se usa para crear/renombrar/resolver el lote: lo determina CODIGO_LOTE. Objetivos permitidos: ENGORDE, REPRODUCCION, REEMPLAZO, OTRO, SIN_DEFINIR; «Cría» se normaliza a REPRODUCCION. No hay objetivo LECHERIA. Etapas Fase 1/2/3, Desarrollo y Engorde son porcinas.

F. FINANZAS

Obligatorias: `FECHA`, `NATURALEZA`, `TIPO_MOVIMIENTO`, `CATEGORIA`, `DESCRIPCION`, `MONTO`, `MONEDA`.

Opcionales: `PRODUCTO`, `CANTIDAD`, `UNIDAD`, `PRECIO_UNITARIO`, `PROVEEDOR`, `DESTINO_USO`, `METODO_PAGO`, `EMPLEADO`, `FINCA`, `OBSERVACIONES`.

`FINCA` es un texto informativo legado; **no es fincaId ni selecciona tenant**. `EMPLEADO` todavía se persiste. Horas, número de personas, depreciación, inventario de bodega o producción de leche no forman parte del DTO y se ignoran con advertencia si aparecen como columnas. No hay reporte de errores exportable CSV/XLSX.

W. PESAJES

Obligatorias: `DIIO`, `FECHA`, `PESO_KG`. Opcionales: `ETAPA_PRODUCTIVA`, `OBSERVACIONES`.

Se acepta DIIO/identificador de un animal existente o incluido en INVENTARIO. La etapa se valida contra enum, pero este mapeador no verifica especie antes de aceptar una etapa porcina; al confirmar tampoco pasa etapa a `validarDatosPesaje`. Hay que alinear esa validación con INVENTARIO.

Hojas auxiliares y correspondencia de plantilla

`INSTRUCCIONES` declara `VERSION_PLANTILLA = 1`; `CATALOGOS` lista valores orientativos. No crean entidades. Sin versión se advierte y se continúa; una versión diferente se rechaza. Las hojas desconocidas se advierten e ignoran; las columnas desconocidas también. Todos los encabezados generados están admitidos por el backend; la discrepancia son aliases omitidos deliberadamente, no columnas obligatorias faltantes. No hay listas desplegables/validaciones de Excel generadas para impedir errores al llenar celdas.

3. Seguridad del archivo y servidor

Versiones y avisos verificados (IM-01, P0)

Instalado y lockfile: **xlsx 0.18.5**, declarado `^0.18.5`; **multer 2.4.0**, declarado `^2.4.0`. Entorno de prueba: Node v24.16.0. No se usa exceljs ni csv-parse en este flujo.

Aviso	Afectación de 0.18.5	Evidencia
CVE-2023-30533 / GHSA-4r6h-8v6p-xvw6	Versiones anteriores a 0.19.3 afectadas por prototype pollution al leer archivos preparados	Aviso oficial de SheetJS y npm audit
CVE-2024-22363 / GHSA-5pgg-2g8v-p4x9	Versiones anteriores a 0.20.2 afectadas por ReDoS	Aviso oficial de SheetJS y npm audit

La exposición es real a nivel de componente: un administrador puede cargar un archivo arbitrario al parser afectado. No se demuestra aquí una explotación del CVE que cambie privilegios o acceda a otra organización. La prueba de encabezados `__proto__` no es un exploit de ese CVE y su resultado negativo **no limpia la vulnerabilidad de la librería**.

`npm audit` identifica xlsx como high, con ambos avisos y `fixAvailable: false` en ese canal npm. Los avisos oficiales remiten a releases del proveedor: no basta asumir que `npm update xlsx` arreglará el problema. Evaluar una versión mantenida, revisar su procedencia y probar compatibilidad antes de sustituir el parser. El rango mínimo que corrige estos dos avisos no certifica ausencia de otros riesgos futuros.

La consulta completa también detectó **proxy-addr**, indirecta, critical, GHSA-jqcg-44mw-7w3h, con corrección disponible. Es un pendiente de dependencias del servidor fuera del parser; no se verificó su explotación ni la configuración del proxy de despliegue. No se suma como un P0 adicional del importador.

Tipo, límites y event loop (IM-02, P0)

- Multer usa memoria y límite de **10 MiB por archivo**. La prueba de tipo es extensión `.xlsx` **o** MIME declarado, no firma/estructura OOXML. El cliente solo comprueba extensión.
- `XLSX.read` y `sheet_to_json` se ejecutan síncronamente en el proceso HTTP. No se limita cantidad de hojas, dimensiones declaradas, filas, columnas, longitud de celda, bytes descomprimidos o relación de compresión. No hay worker aislado ni timeout del parser.
- Los registros completos se guardan en un solo documento ImportacionExcel Mixed. Un libro comprimido pequeño puede exceder el límite de documento de MongoDB al materializarse; no se controla previamente. No se ejecutó ese rechazo contra MongoDB.
- No se observa caducidad TTL de los previews ni cuota específica de cargas. Muchos previews pueden consumir almacenamiento. Auth/rol limitan quién puede hacerlo, pero no el costo de un archivo autorizado sobre el proceso compartido.

Pruebas con archivos

Todos los archivos se construyen en memoria en el reproductor; el caso peligroso de dimensiones se limita en un proceso hijo.

Archivo / entrada	Resultado observado
Plantilla XLSX generada	Seis hojas esperadas, encabezados generados admitidos
XLSX truncado a 80 bytes	Parser rechaza; el controlador convierte la excepción en 400
CSV simple	Parser lo reconoce como una hoja genérica, pero preview es inválido por no tener hoja estándar; CSV no es funcionalidad oficial
XML Spreadsheet con hoja INVENTARIO	Preview válido aunque el buffer no es ZIP/XLSX; con nombre `.xlsx` pasa el filtro de ruta
2.000 filas con descripción de 8.192 caracteres	Buffer comprimido **299.964 bytes**, texto repetido **16.384.000 bytes**, aceptado. Parseo medido alrededor de **448 ms**; un temporizador de 0 ms no se ejecutó durante el trabajo
XLSX con dimensión `A1:XFD1048576`, 8.597 bytes	No terminó antes de **3 segundos** y el proceso hijo fue terminado por timeout. Prueba de agotamiento por dimensión, independiente de demostrar ReDoS del CVE
Encabezados `__proto__`, `constructor`, `$set`, organizacionId/fincaId	Se ignoran con advertencia; no se mapearon a datos ni se observó contaminación de Object.prototype
Catálogo con `=1+1` y `@texto` al generar XLSX	Celda de texto (`t: s`), sin propiedad de fórmula `f`; no ejecución de fórmula demostrada

La compresión de ~54,6:1 probada es acotada; no se afirma haber ensayado la peor zip bomb posible. Es suficiente para confirmar ausencia de límites de descompresión y bloqueo del event loop. Las cifras son observaciones de esta máquina, no un benchmark de producción.

Fórmulas, operadores y DTO

El importador no evalúa fórmulas: SheetJS aporta el valor almacenado/caché, y el mapeador consume valores. Fórmulas sin valor utilizable pueden generar errores de campo; una caché obsoleta puede importar un número obsoleto. No hay cálculo de Excel en servidor ni validación explícita que prohíba celdas con fórmula.

No hay escape específico para prefijos `=` `+` `-` `@` en cadenas, pero tampoco exportación CSV de errores. React renderiza texto y el XLSX de plantilla genera celdas string: no se confirmó una cadena de ejecución de fórmulas en ese recorrido. Probar cualquier futuro exportador CSV antes de habilitarlo; no presentar la sola presencia de `=` como explotación.

El mapeo es una lista de campos explícitos, no un spread libre de las columnas a MongoDB. Los encabezados normalizados se resuelven con Map y las celdas no se parsean como objetos JSON/operadores. `sinVacios` no es por sí solo un DTO de seguridad: su confianza procede del snapshot construido por el servidor. No se confirmó inyección de operadores por Excel ni por payload de confirmación.

4. Aislamiento tenant y vista previa/confirmación

`app.js` monta `/api/importar` con `auth`. La autenticación verifica usuario/membresía, organización activa y acceso a finca; establece req.organizacionId/req.fincaId y AsyncLocalStorage. Animal, Potrero, Lote, Pesaje, MovimientoFinanciero e ImportacionExcel usan aislamiento Mongoose.

Las búsquedas por código, DIIO y padres reciben organización/finca mediante el plugin, aunque el filtro visible del servicio no las escriba. Se verificó el hook de findOne con un tenant conflictivo y lo reemplazó por el contexto autorizado. La búsqueda de pesajes previos de un animal usa `omitirAislamientoFinca` para su historia, conservando organización; no es una consulta libre de tenant.

La vista previa guarda `registros`, errores, advertencias, hash y usuario en ImportacionExcel. **Sí se escribe el documento de preview**, aunque no se insertan todavía animales/finanzas. El texto de UI «ningún dato se guarda» se refiere a entidades operativas y convendría precisarlo. Los datos completos no se devuelven al cliente; solo muestras de hasta cinco filas por entidad.

Confirmación acepta importacionId y modo; lee el snapshot con `_id + usuario` y los filtros tenant del plugin. Alterar `req.body.registros` no altera lo importado: demostrado con un monto reenviado de 999999 que se ignora, conservando el 100 del snapshot. Cambiar finca debe impedir encontrar el preview de otra finca. No hay una ruta que permita editar libremente sus registros.

IM-03 (P1): confirmación sin adquisición atómica

Se hace `findOne → comprobar Pendiente → aplicar todas las filas → save estado`. Dos solicitudes pueden leer Pendiente a la vez; ambas aplican las filas. La reproducción concurrente del controlador obtuvo dos respuestas 201 y **dos movimientos** del mismo snapshot. No es una prueba de carga HTTP/MongoDB, sino del orden de operaciones del controlador con almacenamiento simulado.

El hash tiene índice no único. La comprobación de archivo confirmado se limita al usuario y estados finales; permite varios previews pendientes del mismo archivo y no se repite como bloqueo atómico al confirmar. Si falla el guardado final del estado o un paso no capturado, puede quedar trabajo realizado y snapshot Pendiente, habilitando replay.

IM-04 (P1): deduplicación financiera insuficiente

FINANZAS siempre hace create. Dos filas idénticas pasan preview; una nueva confirmación de esas filas vuelve a insertarlas incluso con `solo_crear`. El hash evita solo algunos reenvíos del mismo buffer ya confirmado por el mismo usuario/finca; otro usuario autorizado o un libro con bytes distintos puede repetir el negocio. Debe definirse identificador de movimiento importado; un hash indiscriminado de importe/fecha tampoco sería suficiente porque pueden existir gastos legítimos iguales.

No existe una UI de historial/reanudación de importaciones ni endpoint de consulta de resultados por ID en este router, aunque el mensaje de duplicado sugiere revisar el historial. Tras un error parcial, repetir exactamente el mismo buffer puede recibir 409; modificarlo para reintentar puede duplicar filas financieras ya guardadas.

5. Cumplimiento de cupos y planes

Prueba exigida: 300 animales

Libro real con **300 bovinos activos**, organización Esencial bovina vacía, límite configurado **210**. Se ejecutaron `puedeCrearAnimal`, `asegurarPuedeCrearAnimal`, `reservarCuotaPlan` y el importador reales; las colecciones y el contador persistido se sustituyeron por repositorios en memoria.

Etapa	Resultado
Preview	Válido, 300 animales; no anticipa insuficiencia del cupo
Confirmación	210 creados, 90 filas con errores
Reservas	210 adquisiciones para las altas permitidas
Límite final	210, sin exceso observado

No se rechaza el archivo entero ni se valida una reserva de 300 antes de escribir. La reserva es por fila y sí reutiliza el mecanismo normal de altas. **IM-18 (P2)**: presentar como listo un lote que excede cupo y comunicar parcialmente su resultado; no clasificarlo como cupo superable sin evidencia. Con animales preexistentes habría menos capacidad disponible. Esencial porcino tiene **500**, no 210: el ejemplo de 300 solo excede el cupo bovino.

La prueba monoespecie impide crear un porcino **activo** bajo Esencial bovino. Muertos/vendidos nuevos no llaman al permiso de especie/cupo; la validación de líneas de finca puede rechazarlos si esa especie no está habilitada, pero no reemplaza una decisión explícita de plan para históricos. No se demostró desbordamiento concurrente de la reserva MongoDB.

IM-11 (P1): suscripción vigente no cubre toda la importación

La ruta no tiene `requirePlanVigente` y la autenticación no rechaza por sí misma una suscripción Suspendida/Cancelada de organización activa. La comprobación de vigencia ocurre al pedir permiso de especie/alta activa. Potreros, finanzas, pesajes y altas/actualizaciones de animales no activos tienen caminos sin esa comprobación.

Reproducción con plan Suspendido: se rechaza la fila de animal activo, pero **sí se crea un animal Muerto y un movimiento financiero**. No se afirma que el administrador de una organización inactiva pase auth: son estados distintos. Exigir vigencia antes de cualquier

mutación y revalidar al confirmar, con respuesta uniforme y sin efectos parciales por ese motivo.

6. Integridad de datos y experiencia de usuario

Duplicados e identidad (IM-19, P1)

- En archivo, DIIO y código de potrero se comparan normalizando mayúsculas/acentos; pesajes se comparan por DIIO/día. Eso detecta repeticiones de esas claves en el archivo, no finanzas duplicadas.
- `diiosExistentes` ayuda a resolver PESAJES en preview, pero INVENTARIO no muestra cuáles serán actualizaciones ni rechaza todos los DIIO ya existentes: depende del modo elegido al confirmar.
- Los índices reales de Animal son identificador único por organización+finca y DIIO único por organización. Un DIIO de otra finca puede provocar error de unicidad tardío; no implica acceso al animal ajeno. Las comparaciones de consultas son exactas y pueden diferir de la normalización del preview.
- La consulta `$or: [diio, identificadorFinca]` puede encontrar dos animales de la **misma finca**: uno cuyo DIIO coincide con el identificador del otro. Ambos documentos pueden respetar sus índices separados. Se reprodujo un PESAJES que cambia de animal según el orden del repositorio, sin error. Debe resolverse una identidad única o rechazar ambigüedad.
- Los identificadores almacenados como números en Excel se convierten desde valor crudo, no desde formato visible. No se certifica conservación de ceros a la izquierda o números largos ya redondeados por Excel. La plantilla debe exigir texto y el preview advertir representaciones ambiguas.

IM-05 (P1): parcialidad sin atomicidad de fila

Orden: potreros → animales → pesajes → finanzas. No hay transacción del archivo ni de cada conjunto de efectos. La mayoría de errores por fila se capturan y permiten continuar; algunos errores de genealogía/recalcular peso salen de sus bucles sin captura individual.

Caso probado: al fallar el **registro 150 de 300** en FINANZAS, quedan **299 guardados**, con error referido a fila Excel 151 (encabezado ocupa fila 1). No se detiene en 149 ni revierte los anteriores.

Caso probado: Pesaje.create tiene éxito y registrarEventoPesaje falla. Queda un pesaje guardado; el resultado lo cuenta como creado **y** omitido, no se incorpora a animalesAfectados y no se recalcula pesoActual. También hay riesgo de potrero guardado/cobertura fallida y animal cambiado/salida de lote fallida. Las transacciones internas de un servicio de lotes no cubren lo persistido antes por el importador.

Elegir explícitamente contrato «todo o nada» o parcial por filas; en ambos casos, cada fila debe conservar su unidad de efectos, estado e idempotencia.

IM-06 (P1): defaults modifican campos no enviados

INVENTARIO materializa Activo, Sano y SIN_DEFINIR cuando se omiten ESTADO, ESTADO_SANITARIO y OBJETIVO_PRODUCTIVO. `sinVacios` conserva esos defaults, por lo que al actualizar reemplaza datos existentes. Reproducción: animal Vendido/Enfermo/REPRODUCCION terminó **Activo/Sano/SIN_DEFINIR** al enviar solo columnas obligatorias. Tener cupo permite esa reactivación; no es anulación formal de venta.

La promesa «Actualizar sin borrar campos vacíos» no evita esta pérdida semántica. Distinguir columna ausente/vacía de un cambio explícito y aplicar defaults únicamente a altas.

IM-07 (P1): peso actual directo, PES-06 incompleto

En animales nuevos y existentes sin pesajes, `pesoActual` llega desde PESO_ACTUAL_KG a Animal.create/save. Si el existente tiene pesajes, se protege frente a un peso distinto y se elimina un peso idéntico del update. Esa protección parcial **no cumple** la regla de que todo cambio proceda de Pesaje.

Reproducción: animal nuevo con PESO_ACTUAL_KG=123 termina con pesoActual=123, cero Pesaje y cero evento de pesaje. Crear un pesaje inicial con fecha/origen/autor definidos, o retirar esa columna y exigir PESAJES.

IM-08 (P1): relaciones genealógicas sin validación de dominio

La tercera pasada resuelve padres después de crear animales: una madre más abajo **sí puede enlazarse**. Se busca dentro de finca autorizada. Si no existe, se conserva el texto como indica la plantilla.

Solo se selecciona `_id`: no se valida sexo, especie, auto-parentesco, ciclos ni consistencia de fechas. Reproducción: bovina enlazada como hija de un porcino macho y ese mismo macho enlazado como su propia madre. Además, un texto de progenitor nuevo no resuelto puede convivir con un ObjectId de progenitor anterior al actualizar; definir explícitamente esa transición.

IM-09 (P1): filas omitidas o fallidas todavía tienen efectos

Después del bucle principal se recorren **todos** los registros para mover lotes y vincular padres; no solo los guardados correctamente. Reproducción: `solo_crear` devuelve un duplicado omitido, pero el animal cambia de madre y se invoca el movimiento de lote. Una fila que falló antes también puede llegar a esas pasadas si ya existe un animal con su clave. Llevar un conjunto de filas aplicables y no ejecutar efectos posteriores para omitidas/fallidas.

IM-10 (P1): estados finales sin sus hechos

Se acepta Muerto/Vendido en INVENTARIO sin fechaMuerte/fechaVenta, causa, documento de venta o transición completa. No hay columnas de fecha de muerte/venta ni validación «muerte anterior al nacimiento». Se puede crear Muerto sin fecha y editar un activo a estado final; el cierre de pertenencia posterior no reemplaza los efectos sanitarios/reproductivos/financieros ni su trazabilidad.

Definir contrato de carga histórica separado y validar fechas/relaciones; las modificaciones de animales operativos deben pasar por las transiciones existentes, no cambiar solo el enum.

IM-12 (P1): ubicación y estado de potreros sin coherencia operativa

POTREROS aplica defaults Disponible y PASTOREO a registros existentes. Se reprodujo que un banco forrajero Ocupado cambia a Disponible/PASTOREO al importar únicamente código y nombre. No comprueba rotación vigente antes de cambiar estado ni restricciones completas al cambiar tipo/área/capacidad.

POTRERO_CODIGO valida existencia y escribe Animal.potreroActual directamente. No usa el flujo de rotación, no verifica capacidad/tipo del destino y puede divergir del potrero del lote. Los vínculos por CODIGO_LOTE sí usan agregarAnimalesAlLote en una segunda pasada; eso no protege las asignaciones directas sin lote. Reservar movimientos operativos a sus servicios y conservar campos ausentes en actualizaciones.

IM-13 (P1): fechas dependientes del servidor y validación incompleta

Admite DD/MM/AAAA, AAAA-MM-DD, número serial y Date que devuelve `cellDates: true`. Las cadenas validan sus componentes, rechazando fechas como 31/02; un nacimiento sintácticamente válido en **2099** sí pasó preview. No se comprobó el sistema de fechas Excel 1904 ni todos sus seriales límite.

`fecha()` usa getters locales y construye mediodía del servidor; no normaliza con una zona explícita. Archivo idéntico con fecha Excel y texto «15/01/2020»:

TZ de Node	Fecha Excel	Texto DD/MM/AAAA
UTC	2020-01-15T12:00:00Z	2020-01-15T12:00:00Z
America/Costa_Rica	**2020-01-14T18:00:00Z**	2020-01-15T18:00:00Z

Así se cambia el día civil, no solo la hora de almacenamiento. La fecha de PESAJES se valida contra futuro/nacimiento al confirmar, después de que preview puede haberla marcado válida; el día «hoy» convertido a mediodía también puede ser futuro si se confirma antes del mediodía del servidor. Definir conversión de fechas civiles, tratar los seriales con su sistema de libro y usar una misma validación en ambas fases.

IM-14 (P1): números ambiguos aceptados sin aviso

El parser admite coma o punto como decimal y decide por último separador cuando hay ambos. El texto `1,234` se guarda como **1.234**, no 1234; para un usuario que quiso expresar miles hay pérdida de tres órdenes de magnitud sin error. No es un fallo para quien quiso un decimal: el problema es la falta de un contrato explícito y rechazo/advertencia de ambigüedad. Priorizar celdas numéricas nativas, documentar formato y mostrar el valor interpretado antes de confirmar.

IM-15 (P1): contrato financiero parcialmente obsoleto

Moneda sí es obligatoria y se limita a CRC/USD; cada fila conserva su moneda, sin sumas/conversión en importación. Sin embargo, naturaleza y tipo se validan independientemente. **Planilla + Ingreso** pasa preview y la validación del modelo. Esto contradice la decisión de planilla/inversiones solo como egresos.

TIPO_MOVIMIENTO conserva Planilla/Inversion y EMPLEADO sigue en plantilla/DTO/modelo, aunque el producto solicita categorías de egreso sin campos de personas. No se admiten horas, cantidad de personas o depreciación en las columnas del importador, aun cuando

hay campos legados en el modelo general. No se halló importación de stock de bodega ni de lechería; PRODUCTO/CANTIDAD describen movimiento financiero, no stock.

Al confirmar no se recargan catálogos para invalidar una categoría desactivada después del preview. Tampoco se establecen invariantes completas entre monto, cantidad y precio unitario. Alinear el contrato con la decisión de producto y revalidar referencias mutables al confirmar.

IM-16 (P1): falta evento de alta y procedencia en animal

El flujo normal de alta llama `crearEventosInventario`; importarAnimales no lo llama ni genera un evento propio de alta con origen Importación. Animal no recibe referencia al snapshot/fila/autor del importador. El usuario se guarda en ImportacionExcel, pero no basta para una bitácora individual completa. No hay hook de Animal que subsane esa omisión.

PESAJES sí guarda registradoPor, tipoPesaje Importacion y llama registrarEventoPesaje; en edición conserva origen y añade editadoPor. No generalizar la ausencia de bitácora a todos los módulos. Incorporar evento de alta/actualización relevante con importacionId, fila y autor, dentro de la unidad atómica definida.

IM-20 (P1): categoría incompatible sin nacimiento

La comprobación de categoría calculada se ejecuta solo cuando hay especie, sexo **y nacimiento**. Si nacimiento falta (es opcional), basta que la categoría esté en el enum de la especie. Reproducción: **Bovino / Macho / Vaca** pasa preview y la validación Mongoose. Validar incompatibilidades de sexo aun sin edad y representar edad/categoría desconocida sin inventarla. Alinear también etapa porcina de PESAJES con la especie.

IM-17 (P2): errores de confirmación no son accionables en UI

Preview sí presenta hoja, fila, campo y mensaje en español, paginados. Las muestras solo enseñan cinco filas; la muestra financiera **no incluye moneda**, pese a que muestra monto. Los errores finales del backend contienen fila y mensaje, pero la vista final solo presenta creados/actualizados/duplicados/omitidos: no renderiza esos detalles por entidad.

El mensaje «Importación estándar confirmada» aparece también con errores, y un fallo después de persistir puede contarse como omitido aunque no lo esté (IM-05). Mostrar estado parcial inequívoco, moneda, efectos ya aplicados y detalle descargable o consultable de filas, con una reanudación que no reaplique lo correcto. Validar tamaño en cliente y responder errores de Multer con un contrato JSON claro; la ruta no aporta manejador específico para esos errores de middleware.

7. Plan de acción priorizado

ID	Prioridad	Cambio requerido y prueba de aceptación
IM-01	P0	Sustituir/actualizar parser desde fuente verificada; audit sin estos avisos y compatibilidad de plantillas comprobada
IM-02	P0	Validar OOXML real, dimensiones y bytes descomprimidos; límites de filas/celdas, worker con tiempo/memoria y caducidad/cuota de previews. La sonda extrema debe rechazarse rápidamente sin bloquear HTTP
IM-03	P1	Adquirir confirmación de forma atómica y persistir progreso/idempotencia; dos solicitudes producen un solo efecto
IM-04	P1	Identidad de fila/movimiento y política de reintento; nuevo snapshot o usuario no duplica automáticamente un movimiento ya importado
IM-05	P1	Atomicidad de efectos por unidad definida y resultados fieles; fallo de evento no deja pesaje/peso divergente ni fila a la vez creada y omitida
IM-06	P1	Defaults solo en alta; columnas ausentes no reactivan ni cambian sanidad/objetivo
IM-07	P1	PESO_ACTUAL_KG crea Pesaje con fecha/autor o se elimina; todo peso derivable del historial
IM-08	P1	Resolver genealogía por fases con sexo/especie/ciclos/fechas; rechazar auto-parentesco y padres incompatibles
IM-09	P1	No ejecutar lote/genealogía de filas omitidas/fallidas; solo_crear deja al existente intacto

ID	Prioridad	Cambio requerido y prueba de aceptación
IM-10	P1	Contrato histórico y transiciones de estado completas; Muerto/Vendido no se aceptan sin los hechos requeridos
IM-11	P1	Vigencia antes de mutar cualquier entidad; Suspendido/Cancelado no permite escrituras parciales
IM-12	P1	Conservar campos de potrero no enviados y usar reglas de rotación/capacidad/tipo; ubicación animal/lote coherente
IM-13	P1	Fechas civiles independientes de TZ del host, igual resultado para Excel/texto; validar futuro y cronología en preview y confirmación
IM-14	P1	Contrato de números y rechazo de ambigüedad; 1,234 no cambia de magnitud sin aviso
IM-15	P1	Tipos/categorías de egreso, sin campos de personas; validar naturaleza coherente y catálogo vigente al confirmar
IM-16	P1	Eventos de alta/importación y procedencia por fila/autor; bitácora individual trazable
IM-17	P2	Mostrar moneda, estado parcial y errores de guardado por fila; reintento asistido y tamaño explicado
IM-18	P2	Precalcular cupo del archivo y explicar política parcial; 300 bovinos sobre 210 nunca aparecen como totalmente importables sin advertencia
IM-19	P1	Identificador inequívoco; DIIO/identificador cruzados se rechazan o resuelven explícitamente antes de pesar/vincular
IM-20	P1	Validar sexo/categoría sin nacimiento y especie/etapa en PESAJES; Macho/Vaca no se acepta

Secuencia propuesta: parser/límites → adquisición e idempotencia de confirmación → atomicidad y plan → datos/fechas/genealogía → UI/reintento. Preservar los controles que sí funcionan: snapshots en servidor, tenant por sesión, rol administrador, monedas explícitas y reserva atómica de cupo por animal activo.

Para remediar, convertir las reproducciones de defectos a expectativas correctas y añadir integración con MongoDB replica set y HTTP autenticado: dos organizaciones, dos fincas, distintos usuarios, suspensión entre preview/confirmación, índices únicos, fallos de escritura y confirmaciones concurrentes. El verde del reproductor actual significa **defecto reproducido**, no defecto corregido.

Ejecutar evidencia local desde backend:

```
node documentation/auditoria-importaciones.repro.cjs
npm.cmd test
npm.cmd audit --omit=dev --json
```

El reproductor limita automáticamente el caso de dimensiones al proceso hijo; no trasladar ese archivo a un servidor compartido para probarlo.